BUKU PANDUAN PRAKTIS & PEDOMAN RECONNAISSANCE

Riset Lapangan, Bedah Tools, Alur Pengolahan Data, Batasan Hukum, dan Komparasi Utilitas

Penyusun : Mohammad Bagus Satrio

Sifat Dokumen : Buku Panduan / Field Handbook Riset Pribadi (Cybersecurity)

Platform Pengujian: Kali Linux 2026.2 (VirtualBox) - Lab User: nanonim

Bagian A: Metodologi Alur Kerja Reconnaissance Standar

Reconnaissance (Information Gathering) adalah tahap pertama dari seluruh kerangka kerja keamanan siber (Cyber Kill Chain & MITRE ATT&CK - Reconnaissance TA0043). Tujuannya adalah mengumpulkan seluruh data infrastruktur target tanpa melakukan tindakan destruktif.

1. Passive Reconnaissance: Mengumpulkan data publik dari basis data registrar (WHOIS), arsip sertifikat SSL, dan DNS publik tanpa menyentuh server fisik target.

2. DNS & Infrastructure Mapping: Mengubah nama host menjadi alamat IP, memetakan Name Server, dan melacak kepemilikan Autonomous System Number (ASN).

3. Active Network Probing: Memeriksa apakah host hidup (alive) dan memindai port layanan yang terbuka secara terukur.

4. Email Architecture Auditing: Membedah mekanisme autentikasi email (SPF, DKIM, DMARC) untuk mengevaluasi celah spoofing.

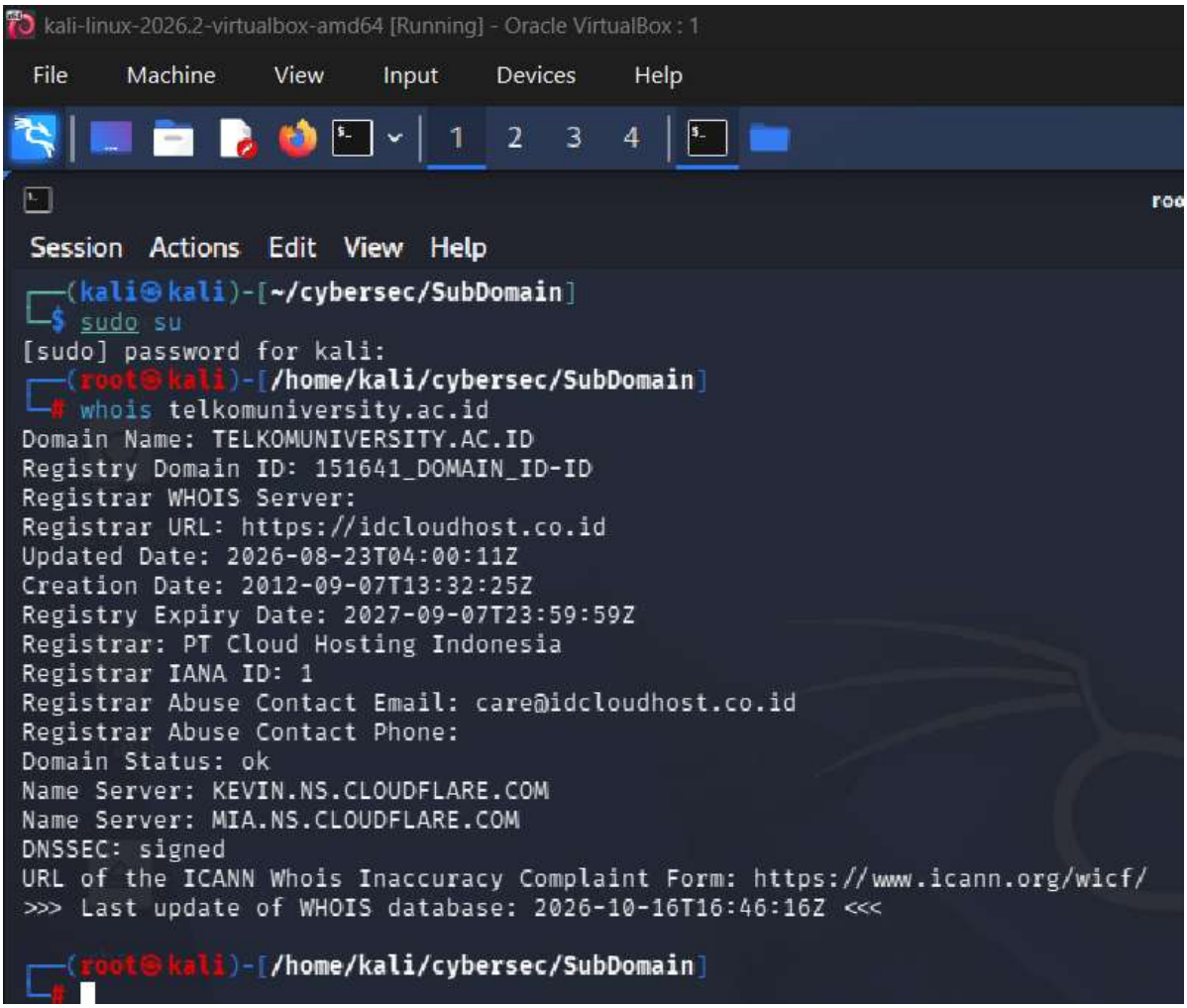
5. Web Application Fingerprinting: Mengidentifikasi tumpukan teknologi web (CMS, plugin, server backend, headers).

Modul 1: WHOIS Intelligence (`whois`)

1.1. Kapan dan Mengapa Digunakan?

Digunakan pada detik pertama penyelidikan untuk mengetahui identitas resmi pemilik domain, masa aktif, dan organisasi pengelola.

```
$ whois telkomuniversity.ac.id
```



Screenshot 1: Hasil eksekusi query WHOIS

1.2. Cara Membaca Output:

• **Registrar:** IDCloudHost (PT Cloud Hosting Indonesia). Alamat email abuse (care@idcloudhost.co.id) adalah kontak resmi jika terjadi insiden siber pada domain.

• **Expiry Date:** 2012 s.d. 2027. Domain aktif dan aman dari risiko Domain Dropping.

• **Name Server:** KEVIN dan MIA Cloudflare. Mengindikasikan domain menggunakan Cloudflare untuk CDN dan mitigasi DDoS.

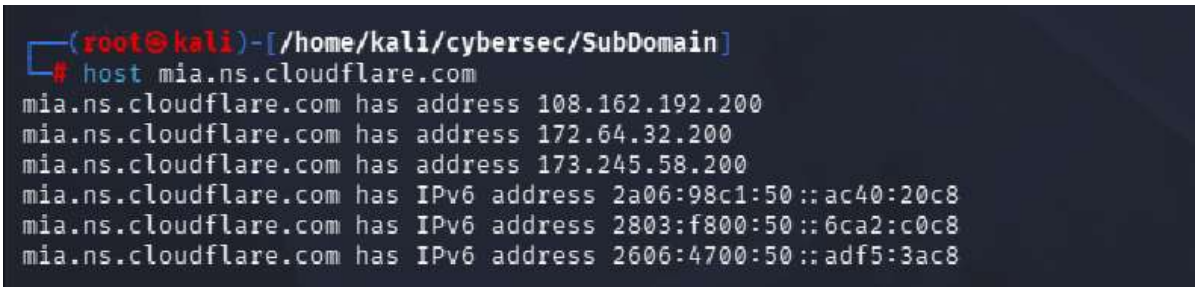
• **DNSSEC:** Status 'signed'. Mengindikasikan proteksi kriptografi aktif terhadap DNS Cache Poisoning.

Modul 2: DNS Mapping & Resolusi Alamat IP (`host` dan `dig`)

2.1. Kapan dan Mengapa Digunakan?

Untuk mengubah nama domain menjadi alamat IP numerik yang dapat dipindai oleh tool jaringan.

```
$ host mia.ns.cloudflare.com
```



Screenshot 2: Resolusi IP name server Cloudflare

Didapatkan alamat IP: 108.162.192.200, 172.64.32.200, dan 173.245.58.200. Munculnya beberapa IP untuk 1 nama host menandakan arsitektur Anycast Load Balancing.

Modul 3: DNS Fingerprinting & Service Detection (`nmap`)

3.1. Kapan dan Mengapa Digunakan?

Untuk mengidentifikasi software DNS server dan versinya pada port 53.

```
$ nmap -sV -sC -Pn -p 53 172.64.32.200
```



Screenshot 3: Fingerprinting nmap pada port 53 DNS

3.2. Bedah Flags Nmap:

- **-p 53:** Targetkan port 53 saja (port standar DNS).
- **-sV:** (Version Detection). Mengirim probe untuk membaca banner versi software.
- **-sC:** (Script Scanning). Menjalankan script NSE default seperti dns-nsid.
- **-Pn:** (No Ping). Melewati tahap ping ICMP agar tidak tertahan firewall.
- **Hasil Analisis:** Software BIND versi 2026.10.2 pada node datacenter 'sin13' (Singapura Changi PoP).

Modul 4: Melacak Autonomous System Number (ASN)

4.1. Kapan dan Mengapa Digunakan?

Untuk mengetahui kepemilikan blok IP dan jalur routing BGP internet.

```
$ whois -h whois.cymru.com 172.64.32.200
```



Screenshot 4: Output query ASN via Team Cymru

• **Hasil:** AS13335 (CLOUDFLARENET). Membuktikan server target berada di bawah payung infrastruktur jaringan global Cloudflare.

Modul 5: Host Alive Discovery & Port Scanning

5.1. Resolusi IP Web Utama:

```
$ host telkomuniversity.ac.id
```

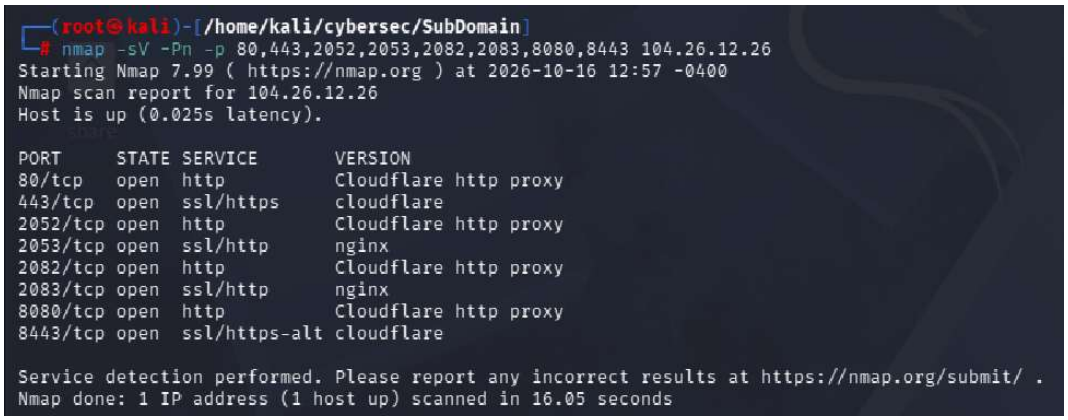


Screenshot 5: Resolusi IP domain web utama

Didapatkan IP aktif: 104.26.12.26, 172.67.75.5, dan 104.26.13.26.

5.2. Port Scanning Ringan & Etis:

```
$ nmap -sV -Pn -p 80,443,2052,2053,2082,2083,8080,8443 104.26.12.26
```



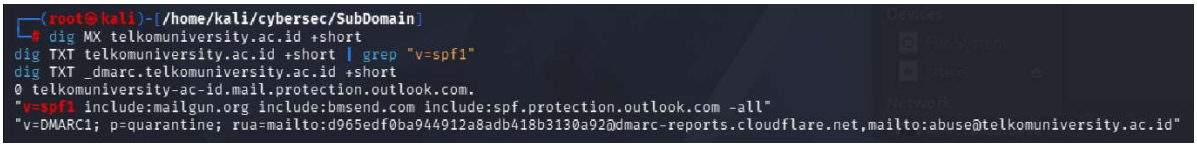
Screenshot 6: Output scan nmap pada IP target

• **Hasil:** Host Alive (latensi 25ms), open ports 80, 443, 2052, 2053, 8080, 8443 (Cloudflare HTTP proxy & Nginx SSL reverse proxy pada Linux).

Modul 6: Analisis Keamanan Email (MX, SPF, DMARC, DKIM)

6.1. Perintah Audit Keamanan Email:

```
$ dig MX telkomuniversity.ac.id +short
dig TXT telkomuniversity.ac.id +short | grep 'v=spf1'
dig TXT _dmarc.telkomuniversity.ac.id +short
```



Screenshot 7: Hasil query MX, SPF, dan DMARC

```
$ dig CNAME selector1._domainkey.telkomuniversity.ac.id +short
dig TXT selector1._domainkey.telkomuniversity.ac.id +short
```



Screenshot 8: Hasil query DKIM Selector

6.2. Evaluasi Parameter Keamanan Email:

• **MX Cluster:** Microsoft 365 Exchange Online Protection.

• **SPF:** include:mailgun.org include:bmsend.com include:spf.protection.outlook.com -all. Kebijakan ketat Hard Fail (-all): email dari luar daftar ini wajib ditolak server penerima.

• **DMARC:** p=quarantine. Email gagal autentikasi diarahkan ke folder spam.

• **DKIM:** Kunci publik RSA 1024-bit yang didelegasikan ke tenant Microsoft kampus.

Modul 7: Subdomain Enumeration & Web Fingerprinting

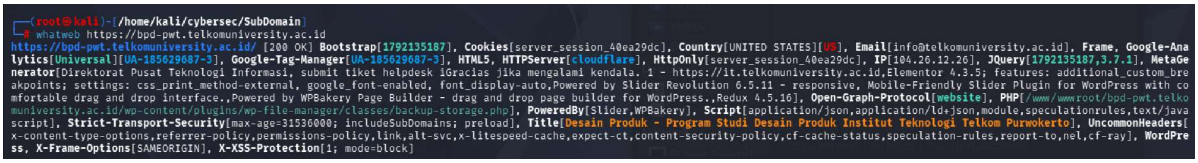
7.1. Pencarian Subdomain Pasif (`subfinder`):

```
$ subfinder -d telkomuniversity.ac.id -silent -o alldomaintelyu.txt
```

Menghasilkan daftar subdomain dari Certificate Transparency logs.

7.2. Fingerprinting Subdomain 1 (bpd-pwt.telkomuniversity.ac.id):

```
$ whatweb https://bpd-pwt.telkomuniversity.ac.id
```

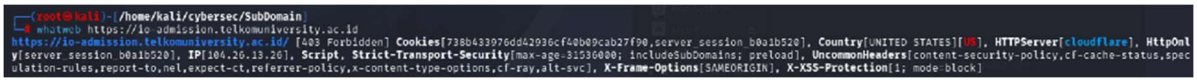


Screenshot 9: Hasil whatweb pada subdomain bpd-pwt

• **Temuan:** 200 OK, CMS WordPress, backend LiteSpeed Cache, PHP Linux (bocoran path /www/wwwroot/...), plugin Elementor 4.3.5, Slider Revolution, WPBakery, Redux, WP File Manager. Security: HSTS, X-Frame-Options: SAMEORIGIN, X-XSS-Protection.

7.3. Fingerprinting Subdomain 2 (io-admission.telkomuniversity.ac.id):

```
$ whatweb https://io-admission.telkomuniversity.ac.id
```



Screenshot 10: Hasil whatweb pada subdomain io-admission

• **Temuan:** 403 Forbidden. Akses ditolak oleh aturan Cloudflare WAF / Access Policy. Security: Content-Security-Policy (CSP), HSTS, X-Frame-Options.

Bagian B: Pemanfaatan Data Reconnaissance (Threat Modeling & Defensive Remediation)

Data reconnaissance yang telah kita kumpulkan bukan sekadar deretan teks mentah. Bagi tim keamanan, data ini diolah menjadi wawasan strategis:

1. Pengolahan Data Subdomain & Teknologi Web:

• **Asset Inventory & CVE Mapping:** Setiap subdomain yang ditemukan dipisahkan berdasarkan tujuannya: web portal publik, aplikasi pendaftaran, atau panel login. Dari versi plugin yang terdeteksi (misal Elementor 4.3.5 atau WP File Manager), tim keamanan mencocokkannya ke database CVE (Common Vulnerabilities and Exposures) untuk memastikan tidak ada celah keamanan publik yang belum ditambal.

• **Remediasi Path Disclosure:** Ketika WhatWeb menemukan path server seperti /www/wwwroot/bpd-pwt..., tim administrator harus mengonfigurasi PHP display_errors = Off agar informasi arsitektur direktori internal server tidak bocor ke publik.

2. Pengolahan Data Email Security:

• **Anti-Spoofing Hardening:** Data SPF, DKIM, dan DMARC dievaluasi untuk mencegah serangan Business Email Compromise (BEC) dan phishing mahasiswa. Konfigurasi '-all' (Hard Fail) dan 'p=quarantine' membuktikan bahwa domain terlindungi secara optimal.

3. Pengolahan Data Port & Jaringan:

• **Attack Surface Reduction:** Daftar open port (80, 443, 2052, 2053, dll.) diperiksa apakah ada port administrasi atau database (seperti port 3306 MySQL atau 22 SSH) yang tidak sengaja terbuka ke internet publik.

Bagian C: Garis Batas Hukum — Kapan Pengolahan Data Berubah Menjadi ILEGAL?

⚠ **PRINSIP UTAMA:** Di dunia cybersecurity, pembeda antara seorang Profesional Keamanan (White Hat / Security Analyst) dan seorang Penjahat Siber (Black Hat) HANYA SATU: IZIN TERTULIS (Authorization / Scope). Memahami garis batas hukum ini mutlak agar Anda tidak berhadapan dengan pasal pidana.

1. Titik Kritis Perubahan Status (The Boundary Line):

• **RECONNAISSANCE PASIF (LEGAL):** Tahap yang Anda lakukan sekarang (membaca respon publik WHOIS, query DNS, melihat header HTTP, memindai port secara ringan) adalah pengumpulan data publik.

• **EKSPLOITASI / PENETRASI TANPA IZIN (ILEGAL):** Aktivitas Anda berubah menjadi TINDAK PIDANA (ILEGAL) begitu Anda mengirim paket data yang dirancang untuk MENEROBOS SISTEM PENGAMANAN, MEMODIFIKASI LOGIKA APLIKASI, MENGAKSES DATA PRIVAT, atau MENGGANGGU LAYANAN.

2. Empat Studi Kasus Transisi dari Legal ke Ilegal:

Kasus 1: Subdomain Discovery vs SQL Injection (SQLi)

• **Fase Legal (Recon):** Seorang analis menemukan subdomain portal pendaftaran menggunakan parameter URL seperti: 'https://subdomain.target.ac.id/detail.php?id=10'.

• **Titik Berubah Ilegal:** Analis tersebut memasukkan tanda petik tunggal (') atau payload seperti '' OR '1'='1' atau menjalankan tool otomatis 'sqlmap -u ... --dbs' untuk membongkar database pengguna tanpa izin tertulis dari kampus.

• **Jerat Hukum:** Melanggar Pasal 30 ayat (1) dan ayat (3) UU ITE No. 1 Tahun 2024 (Mengakses sistem elektronik orang lain dengan cara melanggar atau menerobos sistem pengamanan) dengan ancaman hukuman penjara hingga 8 tahun dan denda miliaran rupiah.

Kasus 2: Port Scanning vs Brute-Force Authentication

• **Fase Legal (Recon):** Nmap mendeteksi port 22 (SSH) atau port 2083 (cPanel) terbuka pada server.

• **Titik Berubah Ilegal:** Analis menjalankan tool seperti 'hydra' atau 'medusa' dengan wordlist ribuan password untuk menebak kredensial login admin secara paksa.

• **Jerat Hukum:** Melanggar Pasal 30 ayat (3) UU ITE (Menerobos pengamanan) dan Pasal 33 UU ITE (Menimbulkan gangguan sistem akibat banjir traffic autentikasi).

Kasus 3: Stale DNS Discovery vs Subdomain Takeover

• **Fase Legal (Recon):** Subfinder menemukan subdomain lama yang tidak aktif (misal 'blog-event.kampus.ac.id') yang memiliki record CNAME mengarah ke layanan cloud luar (misal GitHub Pages atau AWS S3) yang sudah dihapus pemilik aslinya.

• **Titik Berubah Ilegal:** Analis sengaja mendaftarkan nama bucket/repo tersebut di AWS/GitHub untuk mengambil alih subdomain kampus, lalu memasang halaman palsu (deface) atau skrip pencuri password.

• **Jerat Hukum:** Melanggar Pasal 32 UU ITE (Pengubahan atau perusakan informasi elektronik milik orang lain) dan Pasal 35 UU ITE (Manipulasi dokumen elektronik).

Kasus 4: Email Security Audit vs Email Spoofing / Phishing

• **Fase Legal (Recon):** Melihat bahwa suatu domain memiliki record SPF '~all' (Soft Fail) atau DMARC 'p=none', artinya proteksi domain masih lemah.

• **Titik Berubah Ilegal:** Memanfaatkan celah SPF tersebut untuk membuat skrip SMTP pengirim email palsu mengatasnamakan Dekan atau Rektor untuk meminta uang atau mencuri akun mahasiswa.

• **Jerat Hukum:** Melanggar Pasal 35 UU ITE (Pemalsuan Dokumen Elektronik) juncto Pasal 378 KUHP (Penipuan).

Bagian D: Komparasi Perintah Serupa dengan Fungsi & Karakteristik Berbeda

Di dunia keamanan siber, seringkali terdapat beberapa tool yang tampak mengerjakan hal yang sama, namun memiliki arsitektur dan tujuan operasional yang sangat berbeda:

Port Scanning	nmap vs masscan vs rustscan	• nmap: Analisis mendalam, mendeteksi OS & versi (-sV), skrip NSE (-sC). Lambat tapi sangat akurat. • masscan: Port scanner tercepat di dunia (bisa scan jutaan IP/detik menggunakan raw SYN packet). Hanya cek open/close, tanpa version detection. • rustscan: Menggabungkan keduanya. Scan port kilat berbasis Rust, lalu otomatis memanggil Nmap untuk port yang terbuka.
Subdomain Discovery	subfinder vs amass vs assetfinder	• subfinder: Pasif murni, super cepat, membaca CT logs dan search engine tanpa menyentuh target. • amass (OWASP): Paling lengkap

		dan komprehensif, mendukung pasif, DNS brute-force aktif, reverse DNS lookup, dan relasi grafik ASN. • assetfinder: Tool Go minimalis dari TomNomNom, dirancang untuk pipeline terminal cepat (piping ke tool lain).
Web Probing	whatweb vs httpx vs nikto	• whatweb: Mengidentifikasi CMS, teknologi, plugin, dan library dari header/HTML secara pasif/responsif. • httpx: Tool probing HTTP massal super cepat. Digunakan untuk mengecek dari 2000 subdomain mana saja yang memiliki web hidup (HTTP 200/301/403). • nikto: Vulnerability scanner aktif. Mengirim ribuan request untuk mencari file berbahaya (/admin.php, .git, dll.). SANGAT BERISIK dan mudah diblokir WAF.
DNS Querying	dig vs nslookup vs dnsrecon	• dig: Tool standar engineer Linux. Fleksibel, mendukung format +short, query record spesifik (+nostats). • nslookup: Tool interaktif legacy bawaan Windows & Linux. Kurang fleksibel untuk scripting otomatisasi. • dnsrecon: Tool otomatisasi pengujian DNS tingkat lanjut (mencoba Zone Transfer AXFR, enumerasi SRV, dan wildcard).
Header Inspection	curl -I vs wget --spider	• curl -I: Mengirim HTTP HEAD request untuk mengintip header respon server tanpa mengunduh isi file HTML. • wget --spider: Bertindak seperti web spider/crawler untuk mengecek apakah link-link web aktif tanpa menyimpan konten ke harddisk.

Bagian E: Cheatsheet Referensi Cepat Perintah (Quick Reference)

Mencari info registrasi & name server	`whois domain.com`	whois
Mencari IP address dari nama host	`host nama.host.com`	host / dnsutils
Mencari Name Server (NS)	`dig NS domain.com +short`	dig
Mencari Mail Server (MX)	`dig MX domain.com +short`	dig
Mengecek record SPF	`dig TXT domain.com +short | grep v=spf1`	dig
Mengecek record DMARC	`dig TXT _dmarc.domain.com +short`	dig
Mengecek public key DKIM	`dig TXT`	dig

	`selector1._domainkey.domain.com +short`	
Cek ASN pemilik blok IP	`whois -h whois.cymru.com <IP>`	whois
Fingerprint DNS server (port 53)	`nmap -sV -sC -Pn -p 53 <IP-DNS>`	nmap
Port scan & host alive terukur	`nmap -sV -Pn -p 80,443,8080,8443 <IP>`	nmap
Enumerasi subdomain pasif	`subfinder -d domain.com -o subs.txt`	subfinder
Fingerprint teknologi & CMS web	`whatweb https://domain.com`	whatweb
Membaca HTTP header keamanan	`curl -sI https://domain.com`	curl
Probing massal subdomain aktif	`cat subs.txt | httpx -status-code -title`	httpx
Scan port super cepat	`masscan -p80,443 <IP-Range> --rate=1000`	masscan